

Module 1

The 8 CISSP domains

1. Security and Risk management (infosec)

- ↳ define security goals and objectives
- ↳ reduce risk
- ↳ Risk mitigation
 - ↳ having policies in place
- ↳ continuity and compliance
 - ↳ Risk recovery plans and work policies

2. Asset security

- ↳ Secure digital and physical assets
- ↳ Storage, maintain and deletion

3. Security architecture

- ↳ optimize security by tools and policies
- ↳ Shared responsibility, policies

4. Communication and network security

- ↳ includes security when connecting remotely
- ↳ manage communication channels

5. Identity and access management (IAM)

- ↳ Access and Authentication by ensuring policies are followed
 - ↳ Reduce risk
- ↳ Identification
- ↳ Authentication
- ↳ Authorization
- ↳ Accountability

6. Security assessment and testing

- ↳ collecting and analysing data
- ↳ conducting audits
- ↳ Control testing
 - ↳ do the controls achieve the business goals

7. Security operations

- ↳ investigations and recovery
- ↳ Digital forensics
- ↳ DFIR
 - ↳ when? how? why?

8. Software dev security

- ↳ Secure coding Practices
- ↳ Secure design reviews during design phase.

~~~~~  
Threats, risks, vulnerabilities

assets - have value to organisation

Risk - anything that impacts the CIA of data.

Vulnerability - a weakness that can be exploited by a threat. This can include people.

Ransomware - locks data and demands a ransom to return normal operations

~~~~~  
Surface web - everyone

deep web - requires authentication

dark web - accessed through higher privacy requirements.

~~~~~  
Key impacts

- Financial
- Identity theft
- Reputation

~~~~~  
NIST RMF

Risk management framework

- Prepare → manage before breach
- Categorise → develop processes and tasks
- Select → choose, customise and document controls
- Implement → introduce plans
- Assess → Determine if controls are implemented correctly
- Authorise → Be accountable for risks
- Monitor → Be aware of systems

Module 2

People are the biggest threat to an organisation.
So we need policies and plans to prevent human threats.

Controls are designed to reduce security risks

↙
Encryption - ensures confidentiality
Authentication - ensures integrity
Authorization - ensures availability

CIA triad

- ↳ Confidentiality
- ↳ Integrity
- ↳ Availability

NIST Cybersecurity

CSF - cybersecurity framework
↳ managing security risks

- ↳
- Govern - set clear goals, ensure commitment
 - Identify - manage risk, people, assets
 - Protect - protect through policies, tools, training
 - Detect - identify potential incidents
 - Respond - contain, neutralise risks
 - Recover - return systems back to normal

SP 800-53 - for US government systems

OWASP

open web application security project

- Minimise attack surface
- Least privilege
- Defense in depth → multiple security controls
- Separation of duties but address in different ways
- Simplicity → don't give privileges that could be used for harm
- Fix correctly
- Secure defaults
- Fail Securely
- Don't trust services
- Avoid security through obscurity

Audit planning

- internal / external
- conducted by team
- avoid fires
- bolster security posture

- establish scope → people, assets, policies that might
- Risk assessment → identify threats, risks, impact, priority
- Controls assessment → Review existing assets and controls
- Compliance
- reporting → results communicated to stakeholders.

Administrative → policies, procedures
Physical → prevent physical access
Technical → hardware, software controls

Module 3

Logs - Records of events that occurred



firewall logs

Network logs

server logs

Security information and event management (SIEM) tools

Visualisations through dashboards

↳ looking forward at higher adoption rates for cloud hosted and cloud native SIEMs

↳ SOAR (orchestration, automation, response)

↳ allows for AI to perform analysis

~~~~~  
SIEM

self-hosted → ELK Stack  
→ Splunk enterprise

cloud hosted → splunk cloud

hybrid

## Module 4

### playbooks

A manual providing details about operational actions

### Incident response playbooks

Preparation: mitigate likelihood and risk

Detection and analysis: use processes for data

Containment: prevent further damage

eradication and recovery: complete removal

Post-incident: documentation and lessons learned

Coordination: sharing information